

INFORME DE GESTIÓN DE INCIDENTES CONFORME A ISO 27001

Vulnerabilidad de Inyección SQL (SQL Injection)

Introducción

Este informe detalla la identificación y explotación de una vulnerabilidad de inyección SQL en la aplicación Damn Vulnerable Web Application (DVWA). La prueba se realizó en un entorno controlado y aislado (máquina virtual local, sin exposición a redes externas) con fines exclusivamente educativos, para demostrar una vulnerabilidad común y su impacto potencial sobre la seguridad de las aplicaciones web.

Descripción del Incidente

Durante la evaluación de seguridad de DVWA se detectó una vulnerabilidad de inyección SQL en el módulo "SQL Injection". El nivel de seguridad de la aplicación estaba configurado en "Low", lo que permite que los datos ingresados por el usuario se concatenen directamente en la consulta SQL, sin validación ni parametrización. Esta debilidad permite a un atacante inyectar instrucciones SQL maliciosas a través de los campos de entrada de la aplicación, comprometiendo la confidencialidad e integridad de los datos almacenados en la base de datos.

Proceso de Reproducción

Los pasos para reproducir la vulnerabilidad fueron los siguientes:

- Acceder a la aplicación DVWA mediante el navegador (<http://localhost/DVWA>).
- Iniciar sesión con las credenciales de la aplicación (usuario: admin).
- Establecer el nivel de seguridad en "Low" desde la pestaña "DVWA

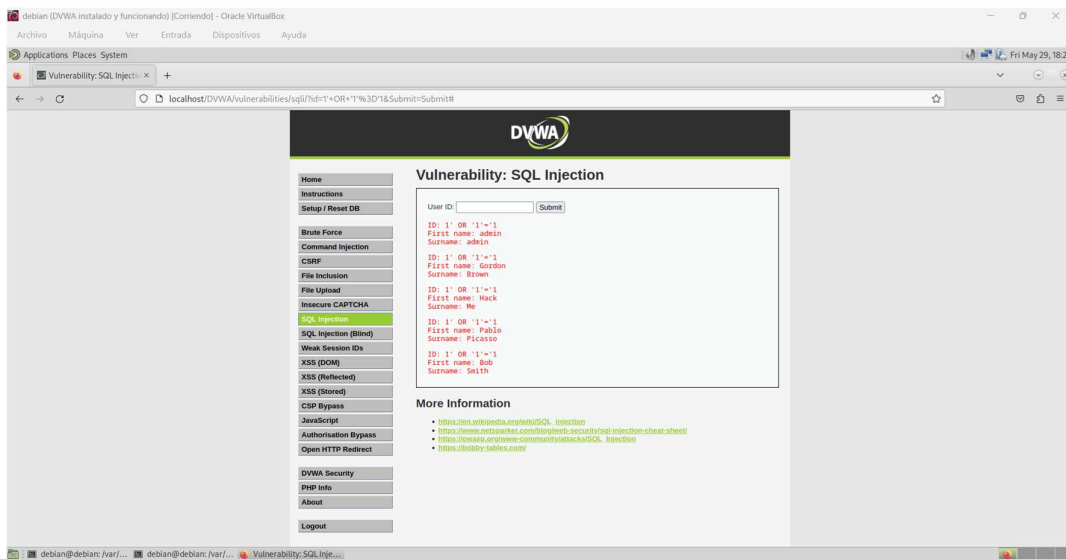
Security".

- Acceder al módulo "SQL Injection".
- Introducir el siguiente payload en el campo "User ID": 1' OR '1'='1
- Pulsar "Submit".

Resultado: en lugar de devolver un único registro, la aplicación devolvió la lista completa de usuarios almacenados en la base de datos (admin, Gordon Brown, Hack Me, Pablo Picasso, Bob Smith).

Explicación técnica: la comilla simple (') cierra prematuramente la cadena esperada por la consulta, y la condición añadida OR '1'='1' es siempre verdadera. Como se une con el operador OR, la cláusula WHERE se cumple para todas las filas, provocando que la base de datos devuelva la tabla completa de usuarios. Esto confirma que la entrada del usuario es interpretada como código SQL.

(Se adjunta captura de pantalla del resultado como evidencia de la explotación.)



Impacto del Incidente

La explotación de esta vulnerabilidad podría permitir a un atacante:

- Acceder y extraer información confidencial de la base de datos, incluyendo credenciales de usuario.
- Modificar, eliminar o comprometer datos sensibles almacenados en la aplicación.
- Eludir mecanismos de autenticación y acceder a funcionalidades restringidas.

Recomendaciones

A partir de los hallazgos de esta evaluación, se recomiendan las siguientes medidas correctivas y preventivas:

- Consultas parametrizadas: utilizar sentencias preparadas para que los datos del usuario nunca se interpreten como código SQL.
- Validación y saneamiento de entradas: aplicar validación estricta de todos los datos suministrados por el usuario (tipo, longitud, formato).
- Principio de mínimo privilegio: la cuenta de base de datos usada por la aplicación debe tener solo los permisos imprescindibles.
- Pruebas de penetración periódicas: realizar auditorías de seguridad y pentesting de forma regular para detectar y mitigar vulnerabilidades antes de que sean explotadas.
- Educación y concienciación: capacitar al personal técnico en prácticas de desarrollo seguro y en los riesgos asociados.

Conclusión

La identificación y explotación exitosa de la vulnerabilidad de inyección SQL en DVWA evidencia la importancia de la seguridad proactiva en el desarrollo y mantenimiento de aplicaciones web. La implementación de controles robustos —en particular el uso de consultas parametrizadas— y el seguimiento de las buenas prácticas de ciberseguridad son esenciales para proteger los activos críticos y garantizar la continuidad del negocio.